

PASTA worksheet

Stages	Sneaker company
I. Define business and security objectives	Business & Compliance Requirements: Seamless Experience: Buyers and sellers must experience frictionless communication and have access to multiple checkout options. Data Privacy: The company highly prioritizes user privacy and is committed to implementing robust data protection measures. Regulatory Compliance: The platform is designed to ensure strict adherence to all relevant data protection regulations and maintain good regulatory standing.
II. Define the technical scope	Technology Stack used by the application: • <i>Application programming interface (API)</i> • <i>Public key infrastructure (PKI)</i> • <i>SHA-256</i> • <i>SQL</i> <i>We implemented API technology to allow merchants to showcase sneakers and products on their own personal storefronts, ensuring customers are seamlessly routed to our app for checkout. To guarantee that communication and transactions are fully secured, we utilized Public Key Infrastructure (PKI) for encryption and the SHA-256 hashing algorithm for data integrity. Finally, to effectively handle customer data and order processing, we selected a robust SQL database to ensure efficient storage and retrieval.</i>
III. Decompose application	Sample data flow diagram
IV. Threat analysis	• <i>Employees been socially engineered open files containing malicious code that can hijack network operations</i> • <i>SQL injection by an external threat actor</i>

V. Vulnerability analysis	• <i>Unsalted SHA-256 Hashing</i> • <i>Broken API Access Control (IDOR)</i> • <i>SQL Injection (SQLi)</i>
VI. Attack modeling	Sample attack tree diagram
VII. Risk analysis and impact	• <i>Deploy a Web Application Firewall (WAF) & API Rate Limiting (General Defense)</i> • <i>Salting SHA-256 Hashing</i> • <i>Implementation of prepared statement</i> • <i>Implement Strict Object-Level Authorization (Targets IDOR)</i>
